

Kolaysoft CTO Dashboard

7. Gün Authentication ve JWT Dokümanı

Doküman Bilgisi	Değer
Proje	Kolaysoft CTO Dashboard
Doküman Türü	Authentication ve JWT Mimari Raporu
Tarih	28 Temmuz 2026
Sürüm	1.0
Durum	Day 7 tamamlandı; registration/refresh token/CRUD yok

1. Amaç

Bu doküman, 7. gün kapsamında tamamlanan JWT tabanlı kimlik doğrulama çalışmalarını açıklar.

Kapsam dışı bırakılanlar:

- Kullanıcı kaydı (registration)
- Refresh token
- CRUD endpointleri
- Frontend authentication UI

2. Authentication Flow

- İstemci POST /api/v1/auth/login ile e-posta ve şifre gönderir.
- AuthController isteği doğrular ve AuthService'e iletir.
- AuthService kullanıcıyı e-posta ile bulur.
- Kullanıcı yoksa 404, pasifse 403, şifre yanlışsa 401 döner.
- Başarılı doğrulamada JwtService access token üretir.
- Cevapta token, userId, role ve fullName döner.
- Sonraki isteklerde istemci Authorization: Bearer <token> gönderir.
- JwtAuthenticationFilter token'ı doğrular ve SecurityContext'e kimliği yerleştirir.

3. JWT Architecture

Bileşenler

Bileşen	Görev
JwtService	Token üretme, doğrulama, subject ve expiration çıkarma
JwtAuthenticationFilter	Bearer token okuma ve authentication kurma
CustomUserDetailsService	E-posta ile kullanıcı yükleme
CustomUserDetails	Spring Security UserDetails adaptörü
PasswordEncoder	BCrypt şifre hashleme

JwtService Metotları

- generateToken(username, claims)
- validateToken(token)
- extractUsername(token)
- extractExpiration(token)

Token Ayarları

Ayar	Ortam Değişkeni	Varsayılan
Secret	JWT_SECRET	Geliştirme varsayılını
Expiration	JWT_EXPIRATION_MS	86400000 (24 saat)

Claims içinde userId, role ve fullName taşınır. Subject alanı e-posta adresidir.

4. Security Configuration

SecurityConfig stateless JWT yaklaşımı kullanır:

- CSRF kapalı
- SessionCreationPolicy: STATELESS
- Form login / HTTP Basic kapalı
- Public endpointler:
 - /api/v1/health
 - /api/v1/auth/login
 - /swagger-ui/**

- /v3/api-docs/**
- Diğer tüm endpointler: authenticated()
- JwtAuthenticationFilter, UsernamePasswordAuthenticationFilter öncesine eklenir

BCrypt PasswordEncoder bean olarak tanımlanmıştır.

5. Login API

Endpoint

POST /api/v1/auth/login

Request

```
{
  "email": "admin@kolaysoft.com.tr",
  "password": "Admin123!"
}
```

Success Response

```
{
  "success": true,
  "message": "Login successful",
  "data": {
    "token": "...",
    "userId": 1,
    "role": "ADMIN",
    "fullName": "System Admin"
  }
}
```

DTO Structure

LoginRequest

- email (zorunlu, e-posta formatı)
- password (zorunlu)

LoginResponse

- token
- userId
- role
- fullName

6. Error Responses

Durum	HTTP	Mesaj
E-posta yok	404	Bu e-posta adresine ait kullanıcı bulunamadı.
Şifre hatalı	401	E-posta adresi veya şifre hatalı.
Kullanıcı pasif	403	Kullanıcı hesabı pasif durumdadır.
Validation	400	Doğrulama hatası.

Ortak hata gövdesi:

```
{
  "success": false,
  "message": "...",
  "data": null
}
```

7. Swagger JWT Bearer Authentication

OpenAPI yapılandırmasına bearerAuth security scheme eklenmiştir.

Swagger UI:

<http://localhost:8080/swagger-ui/index.html>

Authorize alanına Bearer yazmadan yalnızca token değeri girilir; Swagger Bearer şeması prefix'i otomatik ekler.

8. Development Seed User

dev profilinde registration olmadığı için test admin kullanıcısı otomatik oluşturulur:

- E-posta: admin@kolaysoft.com.tr
- Şifre: Admin123!
- Rol: ADMIN

Üretim profilinde seed çalışmaz.

9. Test Results

Çalıştırılan testler:

- AuthControllerTest (MockMvc)
 - başarılı login
 - 404 e-posta yok
 - 401 şifre hatalı
 - 403 pasif kullanıcı
- AuthServiceImplTest
 - aynı iş kuralları unit seviyede
- JwtServiceTest
 - generate / validate / extract
- HealthControllerTest
 - public health erişimi korunur

Beklenen komut:

```
cd backend/cto-dashboard-api
./mvnw test
```

Doğrulan sonu:

- Tests run: 11
- Failures: 0
- Errors: 0
- Skipped: 0
- BUILD SUCCESS

10. Problems Encountered

1. **Registration yokken login testi:** Geliştirme için DevDataInitializer ile seed admin eklendi.
2. **Lazy Role erişimi:** Login sırasında findByEmailWithRole JOIN FETCH sorgusu eklendi.
3. **Health testinin JWT filter bağımlılığı:** HealthControllerTest, yeni SecurityConfig ve filter mock bean'leri ile güncellendi.
4. **Secret yönetimi:** JWT secret ortam değişkeninden okunur; gerçek secret commit edilmez.

11. Next Day Plan

Önerilen Day 8 kapsamı:

1. GET /api/v1/auth/me endpointi

2. Role-based authorization örnekleri (ADMIN / PROJECT_MANAGER / CTO)
 3. User management CRUD başlangıcı (yalnız ADMIN)
 4. Flyway migration geçişı
-

12. Sonuç

Day 7 hedefi tamamlanmıştır. JWT authentication, BCrypt, login API, Swagger Bearer desteęi ve login testleri uygulanmıştır. Registration, refresh token ve CRUD bu gün kapsamında bilinçli olarak eklenmemiştir.